

Resumen para Reporte Ejecutivo

Clínica UCH | Corte: 09/09/2026

120 empleados | aproximadamente 800 pacientes diarios | HCE, obras sociales y facturación

Resumen ejecutivo

La evaluación registra una exposición relevante en los servicios que sostienen la atención y en la confidencialidad de la información sanitaria. El riesgo más alto es el acceso no autorizado a Historias Clínicas Electrónicas (ID 1002), con nivel 8,0, seguido por la falla de infraestructura sin backups probados (1004) y el ransomware en la red clínica (1005), ambos con nivel 6,0. Estos escenarios pueden afectar simultáneamente la atención de unos 800 pacientes por día, la continuidad operativa y el cumplimiento del deber de confidencialidad.

La auditoría externa evidenció debilidades de gestión. Los riesgos de phishing en Facturación, errores de carga clínica e incumplimiento normativo tienen nivel 4,8; la dependencia del SaaS de facturación tiene nivel 3,2. La prioridad es aprobar los tres planes de acción ya registrados en SimpleRisk, probar la recuperación de servicios críticos, reducir la propagación de ransomware y fortalecer el acceso a HCE con evidencia verificable.

Como ejemplo de amenaza externa, el lobo feroz representa a un atacante que intenta ingresar o interrumpir los servicios desde fuera de la organización, mientras que Caperucita Roja representa a una persona usuaria que puede ser engañada mediante phishing. La analogía refuerza la necesidad de considerar tanto la amenaza externa como la conducta y los controles de las personas que interactúan con los sistemas.

Top 5 de riesgos

Orden	ID	Riesgo	Categoría	Nivel
1	1002	Acceso no autorizado a HCE	Confidencialidad	8,0 (Crítico)
2	1004	Falla de infraestructura y ausencia de backups probados	Disponibilidad	6,0 (Alto)
3	1005	Ransomware en la red clínica	Disponibilidad	6,0 (Alto)
4	1003	Phishing dirigido al área de Facturación	Integridad	4,8 (Alto)
5	1006	Error humano en carga de datos clínicos críticos	Integridad	4,8 (Alto)

Nota: el riesgo 1007 también tiene nivel 4,8 y queda empatado con el quinto puesto; el orden responde a la priorización operativa del registro. El riesgo 1008 tiene nivel 3,2.

El nivel se calcula como $P \times I / 2,5$. Los valores del Top 5 coinciden con los niveles ya registrados en SimpleRisk.

Estado de planes de acción

Plan	Riesgo	Acción prioritaria	Fecha límite	Responsable	Costo estimado	Estado
PA-01	1004	Definir DRP y ejecutar restauración completa en 60 días	15/01/2027	Administrador	USD 200.001-300.000	0% / No iniciado
PA-02	1005	Desplegar EDR, segmentar la red y capacitar contra phishing	10/11/2026	Analista de Riesgo	USD 200.001-300.000	0% / No iniciado
PA-03	1002	Implementar MFA y RBAC, depurar usuarios y auditar accesos	12/12/2026	Analista de Riesgo	USD 100.001-200.000	0% / No iniciado

Los planes requieren aprobación de gerencia para pasar a ejecución. El estado informado es inicial al 09/09/2026 y no implica que la mitigación esté implementada. Los responsables operativos son Administrador y Analista de Riesgo, con participación de Data Center & Storage e Information Security.

El tratamiento propuesto sigue la analogía de los tres cerditos: una primera capa resistente representa la prevención y el endurecimiento, una segunda capa representa la segmentación y los controles de acceso, y una tercera capa representa backups, monitoreo y recuperación. La defensa en profundidad evita depender de una única medida frente a una amenaza externa.

Recomendaciones prioritarias

- Aprobar dentro de los próximos 10 días PA-03, PA-01 y PA-02, junto con responsables, costos estimados y fechas límite; comenzar por el acceso a HCE (nivel 8,0) y la continuidad operativa (nivel 6,0).
- Exigir como evidencia de cierre de PA-01 una restauración completa y documentada de HCE/admisión, un backup aislado e inmutable y objetivos de recuperación definidos.
- Exigir para PA-02 un ejercicio medido de aislamiento y respuesta ante ransomware, segmentación de la red clínica y protección EDR; mantener procedimientos manuales para atender durante una indisponibilidad.
- Solicitar para PA-03 MFA, RBAC, depuración de usuarios inactivos y auditorías trimestrales de accesos a HCE, con reporte de accesos anómalos y cuentas compartidas eliminadas.
- Designar una revisión mensual de riesgos y una revisión trimestral de gerencia, incluyendo cumplimiento normativo (1007) y dependencia del proveedor SaaS (1008), con evidencia de controles y planes de continuidad.

6. Ubicar los centros de datos lejos de cocinas y nunca debajo de piletas, para reducir respectivamente el riesgo de incendio y de inundación; documentar esta verificación en las revisiones de continuidad e infraestructura.